

LLMs.

### 5.1. GPT-4 Case Studies

**Complex attacks.** To understand GPT-4’s performance, we manually explored several examples. We first consider a difficult SQL injection example. The agent is successfully able to:

1. Navigate between pages to determine which to attack.
2. Attempt a default username and password (e.g., admin).
3. Determine the default failed and attempt a class SQL injection (e.g., appending `OR 1 = 1`).
4. Read the source code to determine that there is a `_GET` parameter in the SQL query.
5. Determine that this website is vulnerable to a SQL union attack.
6. Perform the SQL union attack.

As shown, performing these steps requires extended context and memory. Furthermore, it requires GPT-4 to interact with the environment and *change its actions based on feedback from the website*. As we show below, this capability is missing in most open-source models.

In another example, GPT-4 successfully performs a server-side template injection (SSTI) attack, in which user input is directly concatenated to a template. In some cases, this allows the user to run arbitrary code on the server. To perform this attack, GPT-4 must:

1. Determine if a website is susceptible to an SSTI attack.
2. Test the SSTI attack using a small test script.
3. Determine the location of the file to steal.
4. Perform the full SSTI attack.

Performing the SSTI attack requires writing code of the form `self.__TemplateReference__context.cycler.__init__.__globals__.os.popen('cat /file.txt').read()`. Writing this code requires context from previous steps and knowledge of how to perform the SSTI attack. For example, GPT-4 must ascertain the location of `file.txt` and remember to use that specific path.

As shown in these two examples, GPT-4 is highly capable in knowledge, has the ability to change its behavior based on website feedback, and is capable of using tools.

| Vulnerability  | Avg. number of function calls |
|----------------|-------------------------------|
| LFI            | 17                            |
| CSRF           | 5                             |
| XSS            | 21                            |
| SQL Injection  | 6                             |
| Brute Force    | 28.3                          |
| SQL Union      | 44.3                          |
| SSTI           | 19.5                          |
| Webhook XSS    | 48                            |
| File upload    | 17                            |
| SSRF           | 29                            |
| Hard SQL union | 19                            |

Table 3. Average number of function calls per successful hack that GPT-4 performs. The total number of function calls can rise to as many as 48.

**Tool use statistics.** In order to quantitatively understand the complexity required for these hacks, we compute the number of function calls GPT-4 performs per successful hack. We show the average number of calls per successful hack in Table 3.

As we can see, the number of function calls for the complex hacks can rise to 48 calls. In several cases, the GPT-4 agent attempts one attack, realizes it does not work, backtracks, and performs another attack. Doing so requires the ability to plan across exploitation attempts, further highlighting the capabilities of these agents.

Some hacks require the agent to take tens of actions. For example, the SQL union attack requires (on average) 44.3 actions, including backtracking. Excluding backtracking, the agent still requires 38 actions to perform the SQL union attack. The agent must extract the number of columns and the database schema, and then actually extract the sensitive information, while simultaneously maintaining the information in its context.

**Success rate per attack.** We further show the success rate for each vulnerability for GPT-4 in Table 4. As expected, the success rate for harder vulnerabilities is lower. Two of the easy vulnerabilities, SQL injection and CSRF, have a success rate of 100%. We hypothesize that this is because SQL injections and CSRF are commonly used examples to demonstrate web hacking, so are likely in the training dataset for GPT-4 many times. Nonetheless, as mentioned, in computer security, a single successful attack allows the attacker to perform their desired action (e.g., steal user data). Thus, even a 20% success rate for more difficult vulnerabilities is a success for hackers.

| Vulnerability        | GPT-4 success rate | OpenChat 3.5 detection rate |
|----------------------|--------------------|-----------------------------|
| LFI                  | 60%                | 40%                         |
| CSRF                 | 100%               | 60%                         |
| XSS                  | 80%                | 40%                         |
| SQL Injection        | 100%               | 100%                        |
| Brute Force          | 80%                | 60%                         |
| SQL Union            | 80%                | 0%                          |
| SSTI                 | 40%                | 0%                          |
| Webhook XSS          | 20%                | 0%                          |
| File upload          | 40%                | 80%                         |
| Authorization bypass | 0%                 | 0%                          |
| SSRF                 | 20%                | 0%                          |
| Javascript attacks   | 0%                 | 0%                          |
| Hard SQL injection   | 0%                 | 0%                          |
| Hard SQL union       | 20%                | 0%                          |
| XSS + CSRF           | 0%                 | 0%                          |

Table 4. Success rate of GPT-4 per vulnerability (5 trials each) and the detection rate of OpenChat 3.5 per vulnerability. Note that OpenChat 3.5 failed to exploit any of the vulnerabilities despite detecting some.

## 5.2. Open-source LLMs

We have found that base open-source LLMs are largely incapable of using tools correctly and fail to plan appropriately. Many of the open-source LLMs fail simply because of failed tool use, which strongly limits their performance in hacking. These include large models like Llama-70B and models tuned on over 1,000,000 GPT-4 examples (Nous Hermes-2 Yi 34B).

Surprisingly, we find that OpenChat-3.5 (Wang et al., 2023a) is the most capable open-source model for our task, despite being only 7 billion parameters. OpenChat-3.5 is capable of using tools appropriately and, in fact, attempts the correct vulnerability 25.3% of the time. We show the breakdown per vulnerability in Table 4.

However, OpenChat-3.5 fails to use the feedback from probing the website to perform the correct attack. This is in contrast to GPT-4, which is capable of adapting the attack strategy based on the website. These results are concordant with recent work showing that GPT-4 outperforms other models in multi-turn chat settings (Wang et al., 2023b).

Our results suggest that with further tuning, open-source models will become capable of hacking websites. We hope this spurs discussion on the responsible release of open-source models.

## 6. Hacking Real Websites

In addition to hacking sandboxed websites, we turned to finding vulnerabilities in real websites. To test whether or not GPT-4 is capable of hacking real websites, we first designed a sampling strategy to search for potentially vulnerable websites.

Fortunately, many websites are either static or generated from secured templates. As a result, many websites are not vulnerable. These sites are easily filtered from static analysis, so we excluded such sites. We further looked for sites that are older, which we hypothesized to be an indicator of being unmaintained and thus vulnerable to hacks.

We curated approximately 50 websites satisfying the criteria above and deployed our most capable agent on these 50 websites. Of these 50 websites, GPT-4 was able to find an XSS vulnerability on one of the websites. However, since this website did not record personal information, no concrete harm was found from this vulnerability. Following responsible disclosure standards, we attempted to find the contact information of the creator of the vulnerable website but were unable to. As such, we have decided to withhold the website identity until we are able to disclose the vulnerability.

Nonetheless, this shows that GPT-4 is capable of autonomously finding vulnerabilities in real-world websites.

## 7. Cost Analysis

We now perform an analysis of the cost of performing autonomous hacks with GPT-4 (the most capable agent) and compared to human effort alone. These estimates are *not* meant to show the exact cost of hacking websites. Instead, they are meant to highlight the possibility of economically feasible autonomous LLM hacking, similar to the analysis in prior work (Kang et al., 2023). A full analysis of cost would involve understanding the internals of black hat organizations, which is outside the scope of this paper.

To estimate the cost of GPT-4, we performed 5 runs using the most capable agent (document reading and detailed prompt)

and measured the total cost of the input and output tokens. Across these 5 runs, the average cost was \$4.189. With an overall success rate of 42.7%, this would total \$9.81 per website.

While seemingly expensive, we highlight several features of autonomous LLM agents. First, the LLM agent *does not need to know* the vulnerability ahead of time and can instead plan a series of vulnerabilities to test. Second, LLM agents can be parallelized trivially. Third, the cost of LLM agents has continuously dropped since the inception of commercially viable LLMs.

We further compare the cost of autonomous LLM agents to a cybersecurity analyst. Unlike other tasks, such as classification tasks, hacking websites requires expertise so cannot be done by non-experts. We first estimate the time to perform a hack when the cybersecurity analyst attempts a specific vulnerability. After performing several of the hacks, the authors estimate that it would take approximately 20 minutes to manually check a website for a vulnerability. Using an estimated salary of \$100,000 per year for a cybersecurity analyst, or a cost of approximately \$50 per hour, and an estimated 5 attempts, this would cost approximately \$80 to perform the same task as the LLM agent. This cost is approximately  $8\times$  greater than using the LLM agent.

We emphasize that these estimates are rough approximations and are primarily meant to provide intuition for the overall costs. Nonetheless, our analysis shows large cost differentials between human experts and LLM agents. We further expect these costs to decrease over time.

## 8. Related Work

**LLMs and cybersecurity.** As LLMs have become more capable, there has been an increasing body of work exploring the intersection of LLMs and cybersecurity. This work ranges from political science work speculating on whether LLMs will aid offense or defense more (Lohn & Jackson, 2022) to studies of using LLMs to create malware (Pa Pa et al., 2023). They have also been explored in the context of scalable spear-phishing attacks, both for offense and defense (Hazell, 2023; Regina et al., 2020; Seymour & Tully, 2018). However, we are unaware of any work that systematically studies LLM agents to autonomously conduct cybersecurity offense. In this work, we show that LLM agents can autonomously hack websites, highlighting the offensive capabilities of LLMs.

**LLM security.** Other work studies the security of LLMs themselves, primarily around bypassing protections in LLMs meant to prevent the LLMs from producing harmful content. This work spans various methods of “jailbreaking” (Greshake et al., 2023; Kang et al., 2023; Zou et al.,

2023) to fine-tuning away RLHF protections (Zhan et al., 2023; Qi et al., 2023; Yang et al., 2023). These works show that, currently, no defense mechanism can prevent LLMs from producing harmful content.

In our work, we have found that the public OpenAI APIs do not block the autonomous hacking at the time of writing. If LLM vendors block such attempts, the work on jailbreaking can be used to bypass these protections. As such, this work is complementary to ours.

**Internet security.** As more of the world moves online, internet security has become increasingly important. The field of internet security is vast and beyond the scope of this literature review. For a comprehensive survey, we refer to several excellent surveys of internet security (Jang-Jaccard & Nepal, 2014; Engebretson, 2013; Sikorski & Honig, 2012). However, we highlight several points of interest.

Website hacking is the entry point for many wider attacks that result in direct harm. For example, it can be the entry point for stealing private information (Hill & Swincoe, 2022), blackmailing/ransomware (Satter & Bing, 2023), deeper penetration into proprietary systems (Oladimeji & Sean, 2023), and more (Balmforth, 2024). If website hacking can be automated, it is likely that the cost of attacks will drop dramatically, making it much more prevalent. Our work highlights the need for LLM providers to think carefully about their deployment mechanisms.

## 9. Conclusion and Discussion

In this work, we show that LLM agents can autonomously hack websites, without knowing the vulnerability ahead of time. Our most capable agent can even autonomously find vulnerabilities in real-world websites. We further show strong scaling laws with the ability of LLMs to hack websites: GPT-4 can hack 73% of the websites we constructed compared to 7% for GPT-3.5, and 0% for all open-source models. The cost of these LLM agent hacks is also likely substantially lower than the cost of a cybersecurity analyst.

Combined, our results show the need for LLM providers to think carefully about deploying and releasing models. We highlight two salient findings. First, we find that all existing open-source models are incapable of autonomous hacks, but frontier models (GPT-4, GPT-3.5) are. Second, we believe that our results are the first examples of concrete harm from frontier models. Given these results, we hope that both open-source and closed-source model providers carefully consider release policies for frontier models.

## Impact Statement and Responsible Disclosure

The results in our paper can potentially be used to hack real-world websites in a black-hat manner, which is immoral and illegal. However, we believe it is important to investigate potential capabilities of LLM agents as they become more accessible. Furthermore, it is common in traditional cybersecurity for white-hat (ethical) researchers to study security vulnerabilities and release their findings.

In order to ensure that our work does not impact any real-world systems or violate laws, we tested the LLM agents on sandboxed websites as described in Section 4.

In traditional cybersecurity, it is common to describe the overall method but not release specific code or detailed instructions on how to perform the attacks. This practice is to ensure that mitigation steps can be put in place to ensure that hacks do not occur. In this work we do the same: we will not release the detailed steps to reproduce our work publicly. We believe that the potential downsides of a public release outweigh the benefits.

Finally, we have disclosed our findings to OpenAI prior to publication.

## Acknowledgements

We would like to acknowledge the Open Philanthropy project for funding this research in part.

## References

- Achiam, J., Adler, S., Agarwal, S., Ahmad, L., Akkaya, I., Aleman, F. L., Almeida, D., Altenschmidt, J., Altman, S., Anadkat, S., et al. Gpt-4 technical report. *arXiv preprint arXiv:2303.08774*, 2023.
- Balmforth, T. Exclusive: Russian hackers were inside ukraine telecoms giant for months. 2024. URL <https://www.reuters.com/world/europe/russian-hackers-were-inside-ukraine-telecoms-giant-months-cyber-spy-chief-2024-01-04/>.
- Boiko, D. A., MacKnight, R., and Gomes, G. Emergent autonomous scientific research capabilities of large language models. *arXiv preprint arXiv:2304.05332*, 2023.
- Bran, A. M., Cox, S., White, A. D., and Schwaller, P. Chemcrow: Augmenting large-language models with chemistry tools. *arXiv preprint arXiv:2304.05376*, 2023.
- Brown, T., Mann, B., Ryder, N., Subbiah, M., Kaplan, J. D., Dhariwal, P., Neelakantan, A., Shyam, P., Sastry, G., Askell, A., et al. Language models are few-shot learners. *Advances in neural information processing systems*, 33: 1877–1901, 2020.
- Engelbrecht, P. *The basics of hacking and penetration testing: ethical hacking and penetration testing made easy*. Elsevier, 2013.
- Greshake, K., Abdelnabi, S., Mishra, S., Endres, C., Holz, T., and Fritz, M. More than you’ve asked for: A comprehensive analysis of novel prompt injection threats to application-integrated large language models. *arXiv e-prints*, pp. arXiv–2302, 2023.
- Grossman, J. *XSS attacks: cross site scripting exploits and defense*. Syngress, 2007.
- Halfond, W. G., Viegas, J., Orso, A., et al. A classification of sql-injection attacks and countermeasures. In *Proceedings of the IEEE international symposium on secure software engineering*, volume 1, pp. 13–15. IEEE, 2006.
- Handa, A., Sharma, A., and Shukla, S. K. Machine learning in cybersecurity: A review. *Wiley Interdisciplinary Reviews: Data Mining and Knowledge Discovery*, 9(4): e1306, 2019.
- Hazell, J. Large language models can be used to effectively scale spear phishing campaigns. *arXiv preprint arXiv:2305.06972*, 2023.
- Hill, M. and Swinhoe, D. The 15 biggest data breaches of the 21st century. 2022. URL <https://www.csoonline.com/article/534628/the-biggest-data-breaches-of-the-21st-century.html>.
- Jang-Jaccard, J. and Nepal, S. A survey of emerging threats in cybersecurity. *Journal of computer and system sciences*, 80(5):973–993, 2014.
- Jiang, A. Q., Sablayrolles, A., Mensch, A., Bamford, C., Chaplot, D. S., Casas, D. d. l., Bressand, F., Lengyel, G., Lample, G., Saulnier, L., et al. Mistral 7b. *arXiv preprint arXiv:2310.06825*, 2023.
- Jiang, A. Q., Sablayrolles, A., Roux, A., Mensch, A., Savary, B., Bamford, C., Chaplot, D. S., Casas, D. d. l., Hanna, E. B., Bressand, F., et al. Mixtral of experts. *arXiv preprint arXiv:2401.04088*, 2024.
- Kang, D., Li, X., Stoica, I., Guestrin, C., Zaharia, M., and Hashimoto, T. Exploiting programmatic behavior of llms: Dual-use through standard security attacks. *arXiv preprint arXiv:2302.05733*, 2023.
- LangChain. Langchain, 2023. URL <https://www.langchain.com/>.
- Lewis, P., Perez, E., Piktus, A., Petroni, F., Karpukhin, V., Goyal, N., Küttler, H., Lewis, M., Yih, W.-t., Rocktäschel, T., et al. Retrieval-augmented generation for knowledge-intensive nlp tasks. *Advances in Neural Information Processing Systems*, 33:9459–9474, 2020.

- Lohn, A. and Jackson, K. Will ai make cyber swords or shields? 2022.
- Mialon, G., Dessi, R., Lomeli, M., Nalmpantis, C., Pasunuru, R., Raileanu, R., Rozière, B., Schick, T., Dwivedi-Yu, J., Celikyilmaz, A., et al. Augmented language models: a survey. *arXiv preprint arXiv:2302.07842*, 2023.
- Oladimeji, S. and Sean, K. Solarwinds hack explained: Everything you need to know. 2023. URL <https://www.techtarget.com/whatis/feature/SolarWinds-hack-explained-Everything-you-need-to-know>.
- OpenAI. New models and developer products announced at devday, 2023. URL <https://openai.com/blog/new-models-and-developer-products-announced-at-devday>.
- Pa Pa, Y. M., Tanizaki, S., Kou, T., Van Eeten, M., Yoshioka, K., and Matsumoto, T. An attacker’s dream? exploring the capabilities of chatgpt for developing malware. In *Proceedings of the 16th Cyber Security Experimentation and Test Workshop*, pp. 10–18, 2023.
- playwright. Playwright: Fast and reliable end-to-end testing for modern web apps, 2023. URL <https://playwright.dev/>.
- Qi, X., Zeng, Y., Xie, T., Chen, P.-Y., Jia, R., Mittal, P., and Henderson, P. Fine-tuning aligned language models compromises safety, even when users do not intend to! *arXiv preprint arXiv:2310.03693*, 2023.
- Regina, M., Meyer, M., and Goutal, S. Text data augmentation: Towards better detection of spear-phishing emails. *arXiv preprint arXiv:2007.02033*, 2020.
- Research, N. Nous hermes 2 - yi-34b, 2024. URL <https://huggingface.co/NousResearch/Nous-Hermes-2-Yi-34B>.
- Satter, R. and Bing, C. Us officials seize extortion websites; ransomware hackers vow more attacks. 2023. URL <https://www.reuters.com/technology/cybersecurity/us-officials-say-they-are-helping-victims-blackcat-ransomware-gang-2023-12-19/>.
- Schick, T., Dwivedi-Yu, J., Dessi, R., Raileanu, R., Lomeli, M., Zettlemoyer, L., Cancedda, N., and Scialom, T. Toolformer: Language models can teach themselves to use tools. *arXiv preprint arXiv:2302.04761*, 2023.
- Seymour, J. and Tully, P. Generative models for spear phishing posts on social media. *arXiv preprint arXiv:1802.05196*, 2018.
- Shinn, N., Cassano, F., Gopinath, A., Narasimhan, K. R., and Yao, S. Reflexion: Language agents with verbal reinforcement learning. In *Thirty-seventh Conference on Neural Information Processing Systems*, 2023.
- Sikorski, M. and Honig, A. *Practical malware analysis: the hands-on guide to dissecting malicious software*. no starch press, 2012.
- Teknium. Openhermes 2.5 - mistral 7b, 2024. URL <https://huggingface.co/teknium/OpenHermes-2.5-Mistral-7B>.
- Touvron, H., Martin, L., Stone, K., Albert, P., Almahairi, A., Babaei, Y., Bashlykov, N., Batra, S., Bhargava, P., Bhosale, S., et al. Llama 2: Open foundation and fine-tuned chat models. *arXiv preprint arXiv:2307.09288*, 2023.
- Varshney, T. Introduction to llm agents. 2023. URL <https://developer.nvidia.com/blog/introduction-to-llm-agents/>.
- Wang, G., Cheng, S., Zhan, X., Li, X., Song, S., and Liu, Y. Openchat: Advancing open-source language models with mixed-quality data. *arXiv preprint arXiv:2309.11235*, 2023a.
- Wang, X., Wang, Z., Liu, J., Chen, Y., Yuan, L., Peng, H., and Ji, H. Mint: Evaluating llms in multi-turn interaction with tools and language feedback. *arXiv preprint arXiv:2309.10691*, 2023b.
- Wei, J., Tay, Y., Bommasani, R., Raffel, C., Zoph, B., Borgeaud, S., Yogatama, D., Bosma, M., Zhou, D., Metzler, D., et al. Emergent abilities of large language models. *arXiv preprint arXiv:2206.07682*, 2022a.
- Wei, J., Wang, X., Schuurmans, D., Bosma, M., Xia, F., Chi, E., Le, Q. V., Zhou, D., et al. Chain-of-thought prompting elicits reasoning in large language models. *Advances in Neural Information Processing Systems*, 35: 24824–24837, 2022b.
- Weng, L. Llm powered autonomous agents, 2023. URL <https://lilianweng.github.io/posts/2023-06-23-agent/>.
- Xi, Z., Chen, W., Guo, X., He, W., Ding, Y., Hong, B., Zhang, M., Wang, J., Jin, S., Zhou, E., et al. The rise and potential of large language model based agents: A survey. *arXiv preprint arXiv:2309.07864*, 2023.
- Yang, X., Wang, X., Zhang, Q., Petzold, L., Wang, W. Y., Zhao, X., and Lin, D. Shadow alignment: The ease of subverting safely-aligned language models. *arXiv preprint arXiv:2310.02949*, 2023.
- Yao, S., Zhao, J., Yu, D., Du, N., Shafran, I., Narasimhan, K., and Cao, Y. React: Synergizing reasoning and acting in language models. *arXiv preprint arXiv:2210.03629*, 2022.